

INVESTIGACIÓN ACERCA DE RANSOMWARE - Jorge Parra ITIT 13104



Universidad La Salle Chihuahua

Seguridad en redes y tecnología de la información II

Practica: Investigación acerca de ransomware

Alumno: Jorge Parra Hidalgo

Semestre: Noveno

Matricula: 13104

Profesor: M.I.A. Erick Rodríguez Arreola

Fecha: 18 de agosto de 2026

1.- Concepto de ransomware

¿Qué es el ransomware?

El ransomware es un tipo de malware que bloquea el acceso a los archivos o sistemas de una persona u organización. Normalmente, los atacantes cifran los archivos y después piden dinero para recuperarlos.

¿Cuál es su principal objetivo?

Su principal objetivo es obtener dinero mediante la extorsión. Los atacantes bloquean información importante para obligar a la víctima a pagar un rescate.

¿Qué características lo distinguen de otros tipos de malware?

A diferencia de otros malware, el ransomware busca principalmente bloquear o cifrar información para exigir un pago. También puede robar información y amenazar con publicarla si la víctima no paga.

¿Qué tipos de ransomware existen?

Los principales tipos son:

- **Locker ransomware:** bloquea el acceso al dispositivo.
- **Crypto ransomware:** cifra los archivos para que no puedan abrirse.
- **Scareware:** utiliza amenazas o mensajes falsos para asustar a la víctima y conseguir dinero.

También existe el Ransomware-as-a-Service (RaaS), donde los creadores del ransomware permiten que otras personas utilicen sus herramientas para realizar ataques.

¿Qué es la doble extorsión?

La doble extorsión ocurre cuando los atacantes hacen dos cosas: primero cifran los archivos y después roban información. Si la víctima no paga, amenazan con publicar los datos robados.

¿Qué consecuencias puede provocar?

Un ataque de ransomware puede provocar:

- Pérdida o bloqueo de archivos.
- Interrupción de las actividades de la organización.
- Pérdidas económicas.
- Robo y publicación de información.
- Daño a la reputación.
- Problemas legales por la exposición de datos.

En resumen, el ransomware es peligroso porque puede bloquear sistemas, robar información y causar pérdidas económicas.

2. Modo de operación

Un ataque de ransomware normalmente no ocurre de manera instantánea. Generalmente se desarrolla en varias etapas, comenzando con la entrada del atacante a un equipo o cuenta de la organización y terminando con el cifrado de información y la exigencia de un rescate.

1. Acceso inicial:

El atacante busca una forma de entrar a la organización. Una de las técnicas más comunes es el phishing, donde se envían correos o mensajes falsos para engañar a los usuarios y conseguir que abran un archivo, entren a un enlace malicioso o proporcionen sus credenciales. También pueden aprovechar vulnerabilidades en programas que no están actualizados, contraseñas robadas o servicios expuestos directamente a Internet.

2. Ejecución del malware:

Después de conseguir acceso, el atacante intenta ejecutar el ransomware o herramientas que le permitan continuar con el ataque. Esto puede suceder cuando el usuario abre un archivo malicioso o cuando el atacante aprovecha una vulnerabilidad para ejecutar código en el sistema.

3. Obtención de privilegios:

Si el acceso inicial corresponde a un usuario con pocos permisos, el atacante puede intentar obtener privilegios mayores. Esto le permite acceder a más recursos y realizar acciones que normalmente no podría hacer una cuenta común.

4. Movimiento lateral:

Una vez dentro de la red, el atacante puede intentar pasar del equipo inicialmente comprometido a otros dispositivos. Para esto puede utilizar credenciales obtenidas, cuentas con permisos elevados o vulnerabilidades en otros sistemas. Esta etapa permite que un ataque que comenzó en una sola computadora termine afectando una gran parte de la red.

5. Acceso a servidores y recursos compartidos:

El atacante puede buscar servidores, carpetas compartidas, bases de datos y otros recursos importantes. Si consigue suficientes permisos, puede acceder a información utilizada por diferentes departamentos o sistemas de la organización.

6. Exfiltración de información:

En algunos ataques, antes de cifrar los archivos, los delincuentes copian información importante y la sacan de la organización. Pueden buscar documentos confidenciales, información de clientes, bases de datos u otros archivos que posteriormente puedan utilizar para presionar a la víctima.

7. Afectación de respaldos:

Los atacantes también pueden intentar localizar y eliminar o inutilizar las copias de seguridad. Esto dificulta que la organización pueda recuperar sus sistemas sin depender de los delincuentes.

8. Cifrado de la información:

Después de conseguir el acceso y preparar el ataque, el ransomware puede comenzar a cifrar archivos y sistemas. Como resultado, los usuarios dejan de poder acceder normalmente a sus documentos, aplicaciones o información.

9. Extorsión y solicitud de rescate:

Finalmente, los atacantes muestran un mensaje en el que informan a la organización que sus archivos fueron cifrados y solicitan un pago para supuestamente recuperar el acceso. Cuando además se robó información antes del cifrado, pueden amenazar con publicarla si la organización no paga. Esto puede convertirse en una forma de doble extorsión.

3. Áreas involucradas en la expansión de un ataque

Un ataque de ransomware puede involucrar diferentes áreas tecnológicas y personas dentro de una organización. Cada una puede facilitar la propagación del ataque o ayudar a detectarlo y detenerlo.

Endpoints

Incluyen computadoras de escritorio, laptops, dispositivos móviles y servidores. Estos pueden ser el punto de entrada del ransomware o convertirse en equipos afectados durante la propagación.

Red

La LAN, Wi-Fi y VPN permiten la comunicación entre los dispositivos. Las VLAN ayudan a separar equipos y limitar la propagación, mientras que los firewalls pueden bloquear conexiones sospechosas. Los servicios y puertos expuestos a Internet pueden ser utilizados por los atacantes para obtener acceso.

Identidad y control de acceso

Los usuarios, contraseñas y cuentas privilegiadas son importantes porque una cuenta comprometida puede permitir el acceso a más sistemas. Active Directory administra muchas de estas cuentas y permisos. La autenticación multifactor agrega una protección adicional contra el uso de credenciales robadas.

Servidores y almacenamiento

Los servidores de archivos, bases de datos, sistemas institucionales, NAS, SAN y almacenamiento en la nube pueden contener información importante. Si el atacante obtiene suficientes permisos, puede afectar o cifrar estos recursos.

Respaldos

Los respaldos locales, remotos, offline e inmutables permiten recuperar información después de un ataque. Sin embargo, los respaldos conectados permanentemente a la red pueden ser afectados por el ransomware, por lo que los respaldos offline e inmutables ofrecen mayor protección.

Personas

Los usuarios pueden ser el punto de entrada mediante phishing, mientras que administradores y personal de soporte tienen permisos que podrían facilitar la propagación si sus cuentas son comprometidas. El personal de ciberseguridad ayuda a detectar y contener el ataque, mientras que los directivos participan en la toma de decisiones durante el incidente.

4. Acciones preventivas

Antes de sufrir un ataque de ransomware, una organización debe implementar medidas que reduzcan la posibilidad de infección y limiten sus consecuencias.

Actualizaciones y parches

Mantener los sistemas y programas actualizados permite corregir vulnerabilidades que los atacantes podrían aprovechar para ingresar a la organización.

Protección de endpoints

El uso de antivirus y herramientas como EDR ayuda a detectar y bloquear ransomware y otras actividades maliciosas en computadoras y servidores.

Segmentación de redes

Dividir la red mediante VLAN y firewalls limita la comunicación entre sistemas y dificulta que el ransomware se propague a otros equipos.

Mínimo privilegio

Los usuarios deben tener únicamente los permisos necesarios. De esta manera, si una cuenta es comprometida, se limita el acceso que puede obtener el atacante.

Autenticación multifactor

El MFA agrega una segunda forma de verificar la identidad, dificultando que un atacante pueda utilizar contraseñas robadas para acceder a los sistemas.

Capacitación de usuarios

Los empleados deben aprender a identificar correos, enlaces y archivos sospechosos, reduciendo el riesgo de que el phishing sea utilizado como punto de entrada.

Respaldos offline o inmutables

Mantener copias de seguridad desconectadas de la red o protegidas contra modificaciones permite recuperar la información aunque el ransomware cifre los sistemas y respaldos conectados.

Pruebas de recuperación

Los respaldos deben probarse periódicamente para comprobar que pueden restaurarse correctamente cuando sean necesarios.

Plan de respuesta a incidentes

Contar con procedimientos definidos permite actuar rápidamente ante un ataque, aislar los equipos afectados y reducir la propagación y el impacto del ransomware.

5. Monitoreo y detección

Las tecnologías de monitoreo permiten identificar actividades sospechosas y detectar un ataque de ransomware antes de que se extienda por toda la organización.

EDR (Endpoint Detection and Response)

Monitorea la actividad de computadoras y servidores, como procesos, archivos y conexiones. Puede detectar comportamientos relacionados con ransomware, como la modificación masiva de archivos. Puede intervenir durante la ejecución y propagación del malware. Su función principal es detectar y contener.

IDS/IPS (Intrusion Detection System / Intrusion Prevention System)

Monitorea el tráfico de la red en busca de conexiones o patrones sospechosos. Puede detectar comunicaciones con servidores maliciosos o movimientos inusuales dentro de la red. Puede intervenir durante el movimiento lateral. Su función principal es detectar y, en el caso del IPS, prevenir o bloquear.

SIEM (Security Information and Event Management)

Recopila y analiza registros de diferentes sistemas, servidores, dispositivos de red y aplicaciones. Puede detectar múltiples accesos sospechosos, intentos de escalamiento de privilegios o actividades anormales. Puede intervenir en varias etapas del ataque. Su función principal es detectar y apoyar la investigación.

Antivirus/Antimalware

Monitorea archivos, programas y procesos en los dispositivos. Puede detectar y bloquear archivos o comportamientos asociados con ransomware. Puede intervenir principalmente durante la ejecución del malware. Su función principal es prevenir y detectar.

Active Directory

Supervisa cuentas, inicios de sesión, permisos y cambios realizados en Active Directory. Puede detectar accesos anormales, uso sospechoso de cuentas privilegiadas o intentos de obtener mayores permisos. Puede intervenir durante el acceso, escalamiento de privilegios y movimiento lateral. Su función principal es detectar y apoyar la investigación.

6. Acciones correctivas y respuesta al incidente

Cuando una organización detecta un ataque de ransomware, debe actuar rápidamente para evitar que se siga propagando. Las acciones deben realizarse en un orden lógico.

1. Identificar los sistemas afectados

Primero se deben identificar las computadoras, servidores y recursos que presentan signos de infección. Esto permite conocer qué tan grande es el problema y evitar tomar decisiones sin información.

2. Aislar los equipos afectados

Los equipos comprometidos deben desconectarse de la red para impedir que el ransomware continúe propagándose hacia otros sistemas.

3. Aislar o segmentar la red

Si el ataque se está extendiendo, se pueden aislar segmentos de la red o bloquear determinadas conexiones. Esto ayuda a contener el incidente mientras se analiza su alcance.

4. Bloquear cuentas comprometidas

Las cuentas que puedan haber sido utilizadas por los atacantes deben bloquearse o limitarse para evitar nuevos accesos y movimientos dentro de la red.

5. Preservar evidencias y analizar logs

Antes de eliminar o modificar sistemas, se deben conservar evidencias como registros, archivos y conexiones. El análisis de logs puede ayudar a determinar cómo comenzó el ataque y qué sistemas fueron afectados.

6. Determinar el alcance e identificar el punto inicial

Se debe investigar cuál pudo ser el punto de entrada, por ejemplo, un correo de phishing, una vulnerabilidad o una cuenta comprometida. También se deben revisar sistemas que aparentemente no fueron afectados.

7. Identificar los IoC (Indicators of Compromise)

Los indicadores de compromiso son evidencias que pueden mostrar la presencia del atacante o del malware, como archivos, direcciones IP, dominios o comportamientos sospechosos. Identificarlos ayuda a encontrar otros equipos comprometidos.

8. Erradicar el malware y recuperar los sistemas

Después de contener el ataque y reunir la información necesaria, se debe eliminar el malware y restaurar los sistemas utilizando respaldos seguros. Antes de volver a conectar los equipos, se debe comprobar que estén limpios y protegidos.

9. Comunicar y escalar el incidente

El incidente debe comunicarse al personal de ciberseguridad, administradores y directivos correspondientes. Esto permite coordinar las acciones técnicas y tomar decisiones sobre la continuidad de las operaciones y las medidas necesarias.

7. Recuperación

Después de contener el ataque, la organización debe recuperar sus sistemas de forma controlada para evitar que el ransomware vuelva a afectar los equipos.

Identificación y verificación de respaldos

Primero se deben identificar respaldos confiables y comprobar que no hayan sido modificados o afectados por el ransomware.

Restauración de sistemas

Los sistemas afectados pueden restaurarse desde los respaldos. Cuando sea necesario, los equipos deben reinstalarse para asegurar que el malware haya sido eliminado.

Recuperación de servicios críticos

Los servicios más importantes deben recuperarse primero para que la organización pueda reanudar sus actividades principales.

Cambio de credenciales y actualización

Se deben cambiar o restablecer las contraseñas de las cuentas comprometidas y aplicar las actualizaciones necesarias para corregir las vulnerabilidades utilizadas durante el ataque.

Monitoreo y regreso a producción

Los sistemas recuperados deben monitorearse de manera reforzada y reincorporarse gradualmente a la producción para detectar cualquier actividad sospechosa.

¿Por qué recuperar la información desde un respaldo no significa que el incidente terminó?

Porque restaurar los archivos no elimina necesariamente la causa del ataque. El malware, las cuentas comprometidas o las vulnerabilidades utilizadas por el atacante pueden seguir presentes. Si los sistemas se restauran sin corregir estos problemas, el ransomware podría volver a entrar y afectar nuevamente la organización.

8. Tecnologías y soluciones contra ransomware

Microsoft Defender for Endpoint (EDR)

Es una solución de seguridad para equipos y servidores que monitorea procesos, archivos y actividades sospechosas. Puede detectar comportamientos relacionados con ransomware y ayudar a aislar los equipos afectados para evitar que el ataque se propague.

Wazuh (SIEM/XDR)

Es una plataforma de seguridad que recopila y analiza información de diferentes equipos y sistemas. Puede detectar actividades anormales, analizar registros y generar alertas que ayuden a identificar un ataque de ransomware.

Veeam Backup & Replication (Respaldos)

Es una solución para realizar y administrar copias de seguridad de sistemas y datos. Puede ayudar a recuperar la información después de un ataque, especialmente cuando se utilizan respaldos protegidos contra modificaciones o almacenados de forma aislada

9. Análisis de un caso real

Un caso conocido es el ataque de ransomware sufrido por la University of California, San Francisco (UCSF) en 2020.

Organización afectada

La organización afectada fue la University of California, San Francisco, específicamente su School of Medicine.

Año del incidente

El ataque ocurrió el **1 de junio de 2020**. UCSF detectó el incidente y comenzó a aislar los sistemas afectados.

Ransomware involucrado

El ransomware fue identificado públicamente como **NetWalker**. La información disponible relaciona al grupo NetWalker con el ataque.

Posible mecanismo de acceso inicial

El mecanismo exacto de acceso inicial no fue confirmado públicamente por UCSF. Por lo tanto, no se puede afirmar con seguridad si los atacantes utilizaron phishing, credenciales robadas o alguna vulnerabilidad.

Sistemas afectados

El ransomware cifró un número limitado de servidores dentro del entorno de TI de la School of Medicine. UCSF logró aislar el incidente y confirmó que la red principal y las operaciones de atención a pacientes no fueron afectadas.

Información comprometida

Los datos cifrados estaban relacionados principalmente con actividades académicas y de investigación. UCSF inicialmente indicó que no creía que los registros médicos de pacientes hubieran sido expuestos. Posteriormente, la universidad notificó que información personal de empleados, estudiantes, colaboradores y participantes de investigación pudo haberse visto afectada.

Impacto operativo

Los servidores afectados quedaron temporalmente inaccesibles, lo que interrumpió parte del trabajo académico y de investigación. Sin embargo, el ataque no afectó la atención de pacientes ni la red principal de UCSF.

Impacto económico

UCSF pagó aproximadamente **1.14 millones de dólares** a los atacantes para obtener una herramienta que permitiera desbloquear los datos cifrados y recuperar la información que habían obtenido.

Tiempo de recuperación

La recuperación comenzó inmediatamente después de aislar los sistemas. UCSF esperaba comenzar a reincorporar algunos sistemas aproximadamente dos semanas después del incidente, y posteriormente confirmó el pago del rescate y el proceso de recuperación.

Acciones realizadas

UCSF aisló los sistemas afectados, contrató especialistas externos de ciberseguridad, inició una investigación, notificó a las autoridades y trabajó para reforzar sus sistemas de seguridad.

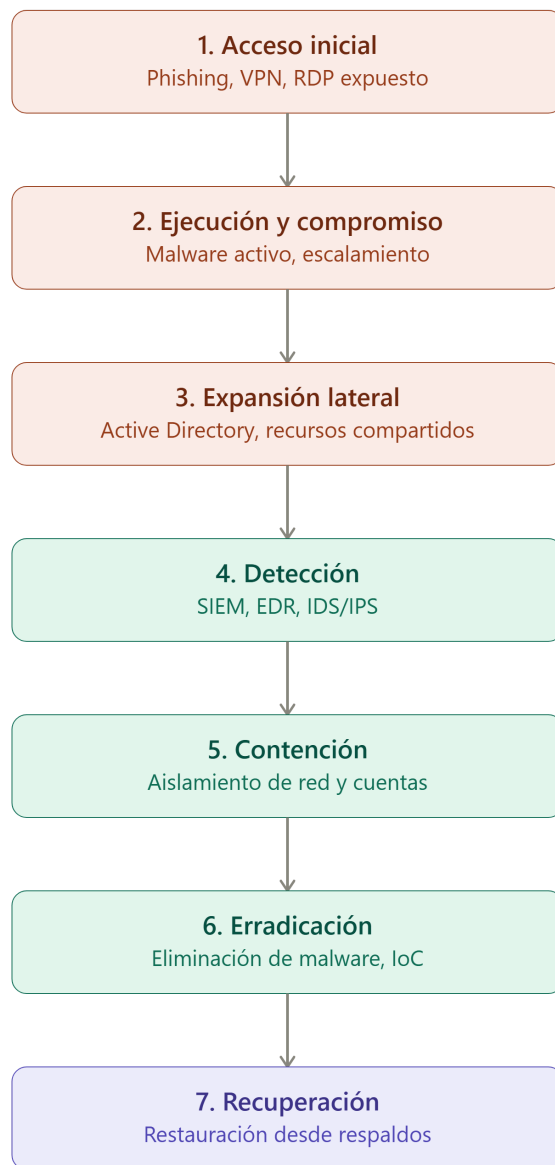
Principales errores o debilidades

No existe información pública suficiente para afirmar con certeza cuál fue la vulnerabilidad que permitió el acceso inicial. Sin embargo, el hecho de que los atacantes lograran cifrar servidores con información importante y que UCSF terminara pagando el rescate muestra la importancia de contar con mecanismos de recuperación adecuados y sistemas críticos correctamente protegidos. Información publicada posteriormente también señaló posibles deficiencias en la protección de datos de los servidores afectados, aunque estos detalles no fueron confirmados oficialmente por UCSF.

Lecciones aprendidas

El caso demuestra la importancia de aislar rápidamente los equipos afectados, contar con respaldos y mecanismos de recuperación confiables, monitorear los sistemas y tener un plan de respuesta ante incidentes. También muestra que un ataque limitado a una parte de la infraestructura puede generar pérdidas económicas importantes y afectar información crítica.

10. Diagrama del ataque



11. Conclusiones

Una organización no puede garantizar que nunca sufrirá un ataque de ransomware, pero sí puede reducir mucho el riesgo y sus consecuencias.

Considero que la prevención y la recuperación son las más importantes, porque la prevención ayuda a evitar el ataque y la recuperación permite volver a operar sin

depender de los atacantes. Los usuarios también son importantes, ya que pueden evitar ataques de phishing si saben reconocer correos y archivos sospechosos.

Los respaldos son indispensables porque permiten recuperar la información después de un ataque. La segmentación de la red ayuda a evitar que el ransomware se extienda fácilmente a toda la organización.

Los controles que considero indispensables son las actualizaciones, MFA, protección de equipos, segmentación de red, respaldos seguros y capacitación de usuarios.

Después de la investigación, considero que el mayor riesgo es la combinación de errores humanos y sistemas mal protegidos, ya que un acceso comprometido puede permitir que el ataque se extienda y cause daños mayores.

12. Referencias bibliográficas

Estas son fuentes confiables que puedes utilizar en formato APA 7:

1. Cybersecurity and Infrastructure Security Agency. (2023). *#StopRansomware Guide*. CISA. [CISA – #StopRansomware Guide](#)
2. National Institute of Standards and Technology. (2012). *Computer Security Incident Handling Guide (SP 800-61 Rev. 2)*. U.S. Department of Commerce. [NIST SP 800-61](#)
3. National Institute of Standards and Technology. (2024). *Cybersecurity Framework (CSF) 2.0*. U.S. Department of Commerce. [NIST Cybersecurity Framework 2.0](#)
4. Cybersecurity and Infrastructure Security Agency. (2021). *Ransomware Guide*. CISA. [CISA Ransomware Guide](#)
5. European Union Agency for Cybersecurity. (2023). *ENISA Threat Landscape 2023*. ENISA. [ENISA Threat Landscape](#)
6. Sophos. (2024). *The State of Ransomware 2024*. Sophos. [Sophos – The State of Ransomware 2024](#)
7. Microsoft. (2024). *Microsoft Digital Defense Report 2024*. Microsoft. Microsoft Digital Defense Report

8. Verizon. (2024). *2024 Data Breach Investigations Report*. Verizon. [Verizon DBIR 2024](#)
9. National Institute of Standards and Technology. (2020). *Security and Privacy Controls for Information Systems and Organizations (SP 800-53 Rev. 5)*. U.S. Department of Commerce. [NIST SP 800-53](#)
10. University of California, San Francisco. (2020). *Update on IT security incident*. UCSF. [UCSF – IT security incident](#)